

내 소개 페이지에 패스키 달기

비밀번호 없이, WebAuthn 패스키로 비공개 영역 잠그기

결과물 makeportfolio-red.vercel.app

소스 github.com/whiteclover0542/portfolio

완주 체크리스트

- ✓ 공개 영역과 비공개 영역을 화면에서 갈라 두었다
- ✓ 패스키를 등록했고, 서버에 저장된 것이 공개키라는 것을 보였다
- ✓ 매번 새 질문이 오고, 이미 쓴 질문은 다시 통하지 않는 것을 확인했다
- ✓ 패스키를 두 개 등록해 하나를 지운 뒤에도 들어갔다
- ✓ 남의 패스키로는 열리지 않는 것을 요청과 응답으로 남겼다
- ✓ 제출물 어디에도 실제 개인정보와 비밀번호가 없다

카드별 진행 — 체크리스트 47 / 47 통과

카드	한 일	결과
01 공개/비공개 분리	PRIVATE 섹션 신설, 비로그인 시 화면·소스·API 전부 차단(401)	6/6
02 패스키 등록	challenge 매번 다름, 서버엔 공개키만 저장, 실기기로 저장 위치(삼성패스) 확인	8/8
03 패스키 로그인	challenge 1회용, 세션 쿠키 발급, 로그아웃 후 재사용 차단	9/9
04 기기 분실 대비	패스키 2개 등록 → 하나 삭제 → 남은 것으로 로그인, 지운 건 차단	5/5
05 교차 검증	계정 2개 양방향 차단, 쿼리·헤더로 계정 스푸핑해도 내 자료만 반환	19/19

짧은 확인 방법

- 1 어디로
<https://makeportfolio-red.vercel.app>
- 2 3단계
주소 접속 → PRIVATE 구역에 아이디 입력 후 "패스키 등록" → 기기 인증 완료 시 비공개 메모·패스키 목록이 바로 열림
- 3 통과 기준
로그인 전엔 비공개 메모가 전혀 안 보임 + 비밀번호 입력 칸이 없음
- 4 안 될 때
패스키 미지원 브라우저면 안내 문구가 뜨고, 취소하면 잠긴 상태 그대로 유지(서버에 아무것도 안 남음)

AI에게 맡긴 일

WebAuthn(SimpleWebAuthn) API 구현, Vercel+Redis 배포, Playwright로 등록·로그인·챌린지 재사용·기기 분실·교차 계정 시나리오 자동 검증

내가 직접 판단한 일

인증 서버 구성(Vercel+Redis), 더미 데이터·계정 모델, "아직 못 막은 것"으로 무엇을 인정할지, Vercel/GitHub 로그인, 실제 기기로 패스키 등록해 저장 위치(삼성패스) 확인

AI 말을 따르지 않은 일

없음 — 제안을 그대로 채택하되 매번 자동화 테스트로 직접 재검증 후 반영

인증 구현 설명서

1 무엇으로 붙였나

@simplewebauthn/server(백엔드) + @simplewebauthn/browser(프론트) 라이브러리. challenge/세션 저장소, 데이터 모델, API 엔드포인트는 직접 구현. 실제 갤럭시 기기로 등록해보니 **삼성패스**에 저장됨.

2 왜 그걸 골랐나

WebAuthn을 직접 구현하면 서명 검증 등에서 실수하기 쉬워 검증된 오픈소스에 맡기고, 저장·세션·API는 직접 설계. GitHub Pages(정적)에서 Vercel(서버리스)+Upstash Redis로 옮겨 challenge 발급·검증을 서버에서 처리.

3 어디를 고쳤나

흐름	위치
등록	api/register-options.js → api/register-verify.js
로그인	api/login-options.js → api/login-verify.js
로그아웃	api/logout.js
비공개 조회	api/private.js, api/passkeys.js (세션 쿠키의 username만 신뢰)

4 안 열리는 것 확인

- 로그인 없이 /api/private → 401
- 남의 패스키로 로그인 시도(양방향) → 401 "이 계정에 등록된 패스키가 아닙니다"
- 성공한 로그인 요청 재전송(challenge 재사용) → 401 "이미 사용됨"
- 삭제된 패스키 id로 로그인 → 401, 남은 패스키로는 성공

5 AI와 나

위 "AI와 내 판단 3줄"과 동일

6 아직 못 막은 것

login-options가 계정 존재 여부에 따라 404/200을 다르게 반환해 아이디 열거(username enumeration)가 가능하고, rate limit도 없음.

PRIVATE

여기서부터는 저만 보는 자리입니다. 비밀번호는 없고, 패스키(기기의 생체인증·PIN)로만 열립니다.
위쪽(WHO AM I ~ PROJECTS)은 이 자리와 상관없이 계속 누구나 볼 수 있습니다.

테스트용 아이디 (실명 아님)

예: whiteclover-test

패스키 등록

패스키로 로그인

▶ 요청-응답 로그 (증거용, 자동 기록 — 최신이 위)

1. 로그인 전

PRIVATE

여기서부터는 저만 보는 자리입니다. 비밀번호는 없고, 패스키(기기의 생체인증·PIN)로만 열립니다.
위쪽(WHO AM I ~ PROJECTS)은 이 자리와 상관없이 계속 누구나 볼 수 있습니다.

테스트용 아이디 (실명 아님)

crop-demo-mtqnwz2l

패스키 등록

패스키로 로그인

패스키 등록 완료 (총 1개). 서버에 저장된 값(공개키): pAEBAYcgBiFYIFtp0hozkmJh...

로그인됨: crop-demo-mtqnwz2l

로그아웃

비공개 메모 (만들어 넣은 더미 데이터)

등록된 패스키

패스키 추가 등록 (기기 분실 대비)

▶ 요청-응답 로그 (증거용, 자동 기록 — 최신이 위)

2. 등록·로그인 직후

Contact

PRIVATE

여기서부터는 저만 보는 자리입니다. 비밀번호는 없고, 패스키(기기의 생체인증·PIN)로만 열립니다.
위쪽(WHO AM I ~ PROJECTS)은 이 자리와 상관없이 계속 누구나 볼 수 있습니다.

테스트용 아이디 (실명 아님)

crop-demo-mtqnwz2l

패스키 등록

패스키로 로그인

패스키 등록 완료 (총 2개). 서버에 저장된 값(공개키): pAEBAYcgBiFYIAssQ71GbyAj...

로그인됨: crop-demo-mtqnwz2l

로그아웃

비공개 메모 (만들어 넣은 더미 데이터)

[더미] crop-demo-mtqnwz2l의 준비 중인 프로젝트 메모 — "답페이크 탐지 v2 아이디어 정리 중"

[더미] crop-demo-mtqnwz2l의 지원 예정 기업 목록 — A사, B사, C사 (가상 이름)

[더미] crop-demo-mtqnwz2l의 이번 달 회고 — "패스키 과제로 WebAuthn 흐름을 직접 구현해봄"

등록된 패스키

내-노트북 · 2026. 9. 7. 오후 12:08:58 · pAEBAYcgBiFYIFtp0hozkmJh...

삭제

패스키 추가 등록 (기기 분실 대비)

▶ 요청-응답 로그 (증거용, 자동 기록 — 최신이 위)

3. 패스키 2개 등록

Contact

PRIVATE

여기서부터는 저만 보는 자리입니다. 비밀번호는 없고, 패스키(기기의 생체인증·PIN)로만 열립니다.
위쪽(WHO AM I ~ PROJECTS)은 이 자리와 상관없이 계속 누구나 볼 수 있습니다.

테스트용 아이디 (실명 아님)

crop-demo-mtqnwz2l

패스키 등록

패스키로 로그인

패스키 삭제됨 (남은 패스키 1개)

로그인됨: crop-demo-mtqnwz2l

로그아웃

비공개 메모 (만들어 넣은 더미 데이터)

[더미] crop-demo-mtqnwz2l의 준비 중인 프로젝트 메모 — "답페이크 탐지 v2 아이디어 정리 중"

[더미] crop-demo-mtqnwz2l의 지원 예정 기업 목록 — A사, B사, C사 (가상 이름)

[더미] crop-demo-mtqnwz2l의 이번 달 회고 — "패스키 과제로 WebAuthn 흐름을 직접 구현해봄"

등록된 패스키

내-노트북 · 2026. 9. 7. 오후 12:08:58 · pAEBAYcgBiFYIFtp0hozkmJh...

삭제

패스키 추가 등록 (기기 분실 대비)

▶ 요청-응답 로그 (증거용, 자동 기록 — 최신이 위)

4. 하나 삭제 후